



Lab Expansion and Learning Roadmap

Purpose: A decision guide for growing the Windows/Active Directory estate in this homelab from a single domain controller into a realistic enterprise identity environment, chosen specifically to teach offensive and defensive security. Written as a mentor would lay it out for someone on the path to IT-security expertise.

Status: Planning. Nothing here is built yet. Current state is one DC (`dc01` , Windows Server 2025, `192.168.50.2`).

1. Where the lab is today

Layer	Present	Notes
Network substrate	pfSense, 6 VLANs, managed switch, Proxmox trunk	Solid foundation
Virtualisation	Proxmox VE, VLAN-aware bridge	New machines should be VMs here
Identity	One DC: <code>dc01</code> / <code>ad.biira.online</code>	Single point; no replication, no member servers, no clients
Attacker	Kali on VLAN 30 (RedTeam)	Ready to use
Defence	Wazuh on VLAN 20 (BlueTeam)	Ready to receive telemetry
Secrets	Vault desktop on VLAN 40 (staged)	Not configured

A single DC can *demonstrate* Active Directory. It cannot *teach* the things that matter for security, because almost every meaningful AD attack and defence involves more than one machine: a workstation to get a foothold, a second DC to replicate, a member server to escalate through, a service account to roast. The goal of this roadmap is to add exactly the machines that unlock those lessons, and nothing that just consumes resources.

2. Guiding principles

1. **Virtual, not physical.** Every addition is a Proxmox VM. Snapshots let you break things on purpose and roll back in seconds, which is how you learn fast. Physical hardware (like DC01) is reserved for cases where you specifically want to learn bare-metal behaviour.

2. **Servers and clients on different segments.** In a real enterprise, workstations do not sit on the same LAN as domain controllers. Modelling that separation is itself a lesson (it is what makes lateral movement non-trivial). See the VLAN note in section 6.
3. **One source of truth per fact.** DC01's build lives in this repo; the IAM workload lives in the IAM repo. Neither should re-document the other's facts. See section 8.
4. **Every machine must justify a lesson.** The tables below pair each machine with the specific skills it unlocks. If a proposed machine does not map to a lesson, it does not get built.
5. **Attack and defend the same event.** For every offensive technique you practise from Kali (VLAN 30), confirm what it looks like in Wazuh (VLAN 20). The value is in the pair, not either half.

3. Recommended endpoint inventory

Priority 1 = build first; the estate is not a security lab without these.

Machine	Role	OS	Where	Priority	Exists to teach
DC01	Domain controller (PDC)	WS 2025	Physical, VLAN 50	Built	AD DS, DNS
DC02	Second domain controller	WS 2025	Proxmox VM, VLAN 50	1	Replication, FSMO, resilience, DCSync/DCShadow
CA01	AD Certificate Services + file server	WS 2025	Proxmox VM, VLAN 50	1	PKI, ESC1–ESC8 cert abuse, SMB/NTFS, BloodHound target
WKS10	Domain-joined workstation	Windows 10	Proxmox VM, client VLAN	1	Foothold, LSASS dumping, GPO, Sysmon
WKS11	Domain-joined workstation	Windows 11	Proxmox VM, client VLAN	2	Lateral movement target, Credential Guard, LAPS
SQL01	SQL Server member	WS 2025	Proxmox VM, VLAN 50	3	Kerberoasting (SPN), service-account abuse
PAW01	Privileged Access Workstation	Windows 11	Proxmox VM, mgmt-adjacent	3	Tiered admin, clean-source principle
LNK01	Linux domain member	Ubuntu	Proxmox VM, VLAN 50	4	SSSD/realmd join, Kerberos on Linux, hybrid reality

Minimum viable security lab: DC01 + DC02 + CA01 + WKS10 + WKS11 = **5 Windows endpoints** (1 physical, 4 VMs). **Rich lab:** add SQL01, PAW01, LNK01 = **8 endpoints**.

Start at the five. Grow when a specific lesson calls for the next machine.

4. What each addition teaches (the deep value)

DC02: second domain controller

- **Replication:** watch changes flow with `repadmin /replsummary`, `repadmin /showrepl`; break and repair it.
- **FSMO roles:** the five single-master roles, how to transfer them cleanly, and how to seize them when a DC dies. This is a real operational skill.
- **Resilience:** shut down one DC and prove logon still works; understand why DNS-on-both matters.
- **Security payoff:** **DCSync** (pretending to be a DC to pull password hashes) and **DCShadow** (injecting rogue directory changes) only make sense once you understand replication. You cannot properly detect what you do not understand.

CA01: AD Certificate Services

- **PKI fundamentals:** root vs issuing CA, certificate templates, enrolment.
- **Certificate-based authentication:** the basis of smartcard/PIV login, and of passwordless directions.
- **Security payoff:** the **ESC1–ESC8** escalation family, misconfigured templates that let a low-privileged user enrol a certificate that impersonates a domain admin. This is among the most impactful modern AD attack classes (tools: Certipy, Certify). Blue side: Wazuh rules for abnormal enrolment.
- Doubles as a **file server:** NTFS vs share permissions, access-based enumeration, honeyfiles/canary tokens.

WKS10 / WKS11: workstations

- **The real starting point of attacks.** No intruder begins on a DC; they begin on a user's machine.
- **Foothold to dominance kill chain:** initial access → local privilege escalation → credential theft (LSASS/Mimikatz) → lateral movement (**PsExec**, **WMI**, **WinRM**, **pass-the-hash**) → domain dominance.
- **Defences to build and test:** **Credential Guard**, **LAPS** (randomised local admin passwords), **AppLocker/WDAC**, **Sysmon** feeding Wazuh.
- **Group Policy** in practice: how policy applies, and how attackers abuse writable GPOs.

SQL01: SQL Server member

- **Kerberoasting:** request service tickets for accounts with an SPN, crack them offline. A SQL service account is the canonical target.
- **Service-account hygiene:** why gMSA (group Managed Service Accounts) exist.

PAW01: Privileged Access Workstation

- **Microsoft's tiered administration model** (Tier 0/1/2): domain admins never log on to normal workstations; the "clean source" principle.
- Turns the abstract idea of admin hygiene into something you can configure and then try to bypass.

LNK01: Linux domain member

- **Hybrid reality:** real enterprises are not all-Windows. Join Ubuntu to AD with `realmd` /SSSD, get Kerberos SSO on Linux, and see how your existing lab Linux boxes could authenticate against AD.

5. Attack and defence scenarios unlocked (the combinations)

Each scenario spans your existing VLANs: **Kali (30)** attacks, the **AD estate (50)** is the target, **Wazuh (20)** observes. This is the purple-team loop.

#	Scenario	Machines needed	Offensive skill	Defensive skill
1	Full kill chain	WKS10, DC02, CA01	phish → foothold → creds → lateral → domain admin	Sysmon + Wazuh detection at each stage
2	BloodHound mapping	Any 3+ machines	collect and map attack paths (SharpHound)	find and cut the paths first
3	Kerberoasting	SQL01 (or any SPN account)	crack service-account tickets	detect TGS requests, enforce gMSA
4	AS-REP roasting	A user with pre-auth disabled	offline crack	audit for DONT_REQ_PREAUTH
5	DCSync → Golden Ticket	DC02	pull <code>krbtgt</code> , forge tickets	detect replication from non-DCs
6	ADCS ESC1	CA01	enrol a cert as domain admin	template hardening, enrolment alerts
7	Pass-the-Hash lateral	WKS10 + WKS11	move without cracking passwords	Credential Guard, LAPS, tiering
8	GPO abuse	WKS10 + writable GPO	push a malicious policy	least-privilege on GPO objects
9	LLMNR/NBT-NS poisoning	WKS10 + Kali (Responder)	capture NetNTLM hashes	disable LLMNR, SMB signing
10	Timeroast / clock attack	any member	abuse NTP/Kerberos skew	monitor time sources

Do not attempt these against anything but this isolated lab. RedTeam reaching the AD estate is opened deliberately for an exercise and closed afterwards; it is never a standing firewall rule (see `docs/11-domain-controller-firewall.md`).

6. Phased build plan

Phase A: make it a domain (Priority 1)

1. Build `DC02` as a Proxmox VM on VLAN 50, join it as a second DC, verify replication.
2. Build `CA01`, install AD CS, publish a couple of templates (one deliberately weak for ESC1 practice later).
3. Build `WKS10`, domain-join it, deploy Sysmon, ship logs to Wazuh.
4. Outcome: the minimum viable security lab; scenarios 1, 2, 5, 6 become possible.

Phase B: enrich the estate (Priority 2)

5. Add `WKS11`; practise lateral movement `WKS10` ↔ `WKS11`.
6. Deploy LAPS and Credential Guard; re-run the lateral scenarios and watch them get harder.
7. Outcome: scenarios 7, 8, 9.

Phase C: realism and hardening (Priority 3–4)

8. Add `SQL01` (Kerberoasting), `PAW01` (tiering), `LNK01` (hybrid).
9. Introduce a dedicated **client VLAN** so workstations are segmented from servers (see note below).
10. Outcome: scenarios 3, 4, 10; a lab that mirrors a real enterprise.

A note on a client VLAN

Today VLAN 50 (EnterpriseLAN) would hold both servers and workstations. That works, but putting workstations on their own segment (a new VLAN 70, or a re-purposed one) teaches the segmentation that makes lateral movement realistic: an attacker on a client subnet must cross a firewall boundary to reach servers, exactly as in production. Worth doing at Phase C, not before, it adds firewall complexity you do not need while learning the basics.

7. Resource budget (reality check)

Proxmox VMs are not free. Rough RAM per VM:

Machine	RAM	Disk
DC02	2–4 GB	60 GB
CA01	2–4 GB	60 GB
WKS10 / WKS11	4 GB each	60 GB each
SQL01	4–6 GB	80 GB

Phase A alone is roughly **10–14 GB RAM and ~240 GB disk** on top of what Proxmox already runs. Confirm the Proxmox host has headroom before building; if RAM is tight, build DC02 and CA01 first, run workstations one at a time, and use Proxmox snapshots aggressively so you can park VMs you are not actively using. Windows Server evaluation ISOs (180 days) are free and ideal for a lab.

8. The IAM repo: keep separate, cross-link, reconcile

The sibling repo `enterprise-iam-lab` builds hybrid identity (on-prem AD + Okta as primary IdP, Entra ID federation planned) on **this same domain**, it references `dc01.ad.biira.online` at `192.168.50.2` directly. They are two layers of one lab:

- **This repo (homelab)** is authoritative for the **infrastructure substrate**: network, VLANs, pfSense, Proxmox, the DC01 build, firewall rules, Wazuh, monitoring.
- **The IAM repo** is authoritative for the **identity workload**: OU design, tiered admin groups, GPO, Okta, SAML/SWA app integrations, federation.

Recommendation: do not merge. The IAM repo carries 223 MB of screenshots and video and reads as a coherent standalone portfolio piece; merging would bloat this repo's history and blur two distinct stories. Instead:

1. Add a line to each README pointing at the other ("Infrastructure substrate: enterprise-security-homelab" / "Identity workload running on this lab: enterprise-iam-lab").
2. **Reconcile two discrepancies now**, because a shared fact documented two ways is worse than either:
 - The IAM repo says Windows Server **2022**; DC01 is now **2025**.
 - The IAM repo labels VLAN 50 as "Management"; this repo calls VLAN 10 Management and VLAN 50 EnterpriseLAN. Pick one naming and fix the other repo.

If a recruiter-facing IAM-only artifact matters to you, separate repos is also the better portfolio choice: someone hiring for IAM sees an IAM repo, not a network lab they have to dig through.

9. Summary recommendation

- **Add DC02 and CA01 as Proxmox VMs**, they unlock replication, PKI, and the attacks that abuse both.
- **Add two workstations**, the real starting point of every attack; without them you cannot learn the kill chain.
- **Target 5 Windows endpoints minimum, 8 for a rich lab.**
- **Keep the IAM repo separate**, cross-link it, and fix the 2022/2025 and VLAN-naming mismatches.
- Build in the phased order above, attacking and defending each addition before moving on.